

SEGURIDAD EN PLATAFORMA

Análisis de caso

Protección de los datos en BioHealth S.A.

Resumen ejecutivo

BioHealth trata información médica y datos identificativos que, por su sensibilidad, requieren el nivel más alto de protección. El principal hallazgo es el uso de datos reales de pacientes en pruebas, acompañado de accesos que no están debidamente controlados. Esta combinación aumenta innecesariamente la posibilidad de divulgación, alteración, copia y uso fuera del propósito original.

La medida inmediata recomendada es detener nuevas copias directas de producción, aislar las existentes y reemplazarlas por conjuntos enmascarados o sintéticos. El plan se completa con RBAC, autenticación multifactor, auditoría centralizada, cifrado híbrido, controles preventivos-detectivos-correctivos y reglas seguras para Google Workspace.

Prioridad	Acción	Resultado esperado
Crítica	Bloquear copias de datos reales hacia pruebas y eliminar copias no autorizadas.	Contención inmediata de la exposición.
Alta	Crear proceso automatizado de enmascaramiento estático y validar irreversibilidad.	Pruebas funcionales sin identificar pacientes.
Alta	Aplicar RBAC, MFA, mínimo privilegio y recertificación.	Accesos coherentes y trazables.
Alta	Cifrar datos en reposo y tránsito con gestión central de claves.	Protección ante interceptación o robo.
Media	Configurar colaboración, retención, alertas y auditoría en Google Workspace.	Reducción del riesgo en correo y documentos.

Criterio de éxito. Ningún entorno no productivo debe contener datos reales identificables salvo excepción documentada, temporal, cifrada y aprobada por el responsable de privacidad y seguridad.

1. Análisis inicial del entorno

1.1 Prácticas que representan un riesgo directo

Práctica observada	Amenaza o debilidad	Consecuencia
Uso de datos reales en pruebas	Duplicación fuera del entorno más controlado y acceso por desarrolladores/testers.	Violación de confidencialidad, privacidad y finalidad.

Práctica observada	Amenaza o debilidad	Consecuencia
Accesos no controlados	Permisos amplios, roles indefinidos o cuentas compartidas.	Consulta, modificación o extracción no autorizada.
Controles no contrastados	No existe claridad sobre estándares ni evidencia de eficacia.	Incumplimiento, respuesta reactiva y falsa sensación de seguridad.
Gobierno de datos insuficiente	No se mencionan clasificación, propietario, retención ni eliminación.	Conservación excesiva y protección inconsistente.
Trazabilidad incierta	No se demuestra quién accede, qué consulta o qué exporta.	Imposibilidad de investigar incidentes y rendir cuentas.
Cifrado no demostrado	No se acredita protección en tránsito, reposo ni backups.	Exposición ante interceptación, pérdida o robo.

Además de los riesgos técnicos, BioHealth enfrenta impactos regulatorios, reputacionales y clínicos. Una alteración de un resultado o historial puede afectar decisiones médicas; una filtración puede causar discriminación, fraude o daño personal; y una indisponibilidad prolongada puede retrasar la atención.

1.2 Por qué los datos reales no deben usarse en pruebas

- Amplían la superficie de exposición al crear copias adicionales y menos controladas.
- Desarrolladores, proveedores y testers pueden acceder a información que no necesitan para su función.
- Los entornos de prueba suelen tener controles, monitoreo y continuidad inferiores a producción.
- Una captura, log, exportación o respaldo de prueba puede conservar información sensible inadvertidamente.
- Contradice los principios de minimización, limitación de finalidad y acceso por necesidad.

Alternativa técnica recomendada. Utilizar datos sintéticos cuando sea posible y, cuando las pruebas exijan relaciones y formatos realistas, generar una copia mediante enmascaramiento estático irreversible antes de introducirla en el entorno no productivo. El proceso debe preservar utilidad y referencialidad, pero impedir la reidentificación.

2. Plan de enmascaramiento de datos sensibles

2.1 Alcance y técnica principal

Se propone un proceso ETL controlado: extraer desde producción mediante una cuenta técnica de solo lectura, transformar dentro de una zona segura, validar el resultado y cargar únicamente la copia enmascarada en pruebas. La técnica principal será el enmascaramiento estático porque modifica permanentemente la copia y evita que los usuarios no productivos consulten los valores originales.

Campo	Clasificación	Técnica	Ejemplo de transformación	Criterio funcional
Nombre y apellido	Dato personal	Sustitución coherente	Ana Pérez → Paciente 004582	Mantener longitud y caracteres válidos.
DNI/documento	Identificador único	Tokenización o aleatorización con unicidad	12.345.678 → 83.641.205	Conservar formato y no repetir valores.
Correo	Dato de contacto	Regla determinística	ana@email.com → paciente4582@pruebas.in valid	Dominio no entregable; mismo paciente, mismo alias.
Teléfono	Dato de contacto	Aleatorización por formato	+56 9 8123 4567 → +56 9 7004 5821	Mantener país y longitud sin número real.
Dirección	Dato personal	Sustitución sintética	Dirección real → Calle Prueba 4582	Preservar estructura para formularios.
Fecha de nacimiento	Dato sensible	Desplazamiento de fecha	1985-04-12 → 1985-06-03	Conservar rango etario y consistencia.
Historia clínica	Dato de salud	Síntesis/redacción y seudonimización	Texto real → caso clínico ficticio equivalente	Eliminar nombres, lugares y eventos identificables.
N.º de historia	Identificador clínico	Token determinístico	HC-009812 → TEST-7F42A1	Mantener relaciones entre tablas.
Resultados de laboratorio	Dato de salud	Datos sintéticos o perturbación controlada	Valor real → valor ficticio dentro de rango	Conservar tipos, unidades y escenarios límite.
Credenciales	Secreto	No copiar; regenerar	Hash/clave productiva → credencial exclusiva de prueba	Nunca reutilizar secretos de producción.

2.2 Reglas por rol y entorno

Rol	Producción	Pruebas	Visualización
Médico tratante	Acceso por relación asistencial.	Sin acceso ordinario.	Datos reales solo para atención autorizada.
Administrador clínico	Funciones administrativas limitadas.	Datos enmascarados.	Ocultar contenido clínico no necesario.
Tester/desarrollador	Sin acceso a datos reales.	Copia estática enmascarada.	Datos ficticios con formato realista.
Soporte	Acceso temporal y aprobado.	Enmascaramiento dinámico parcial.	Mostrar últimos caracteres solo si es necesario.
Administrador de BD	Acceso privilegiado controlado por PAM.	Copia enmascarada; acceso registrado.	No debe usar datos fuera de tareas aprobadas.
Auditor/DPO	Acceso de consulta a evidencias.	Acceso a logs y reglas.	Información mínima para verificar cumplimiento.

2.3 Flujo y validaciones

Etapas	Actividad	Evidencia
1. Descubrimiento	Inventariar tablas, archivos, logs y campos sensibles; asignar propietario.	Catálogo y clasificación aprobados.
2. Diseño	Definir regla por campo, consistencia, irreversibilidad y excepciones.	Matriz de enmascaramiento.
3. Transformación	Enmascarar en zona segura antes de cargar en pruebas.	Job automatizado y registros.
4. Validación	Comprobar formato, unicidad, referencialidad y utilidad funcional.	Pruebas técnicas y de negocio.
5. Privacidad	Intentar reidentificación y revisar datos residuales en texto libre/logs.	Informe de riesgo residual.
6. Carga y acceso	Cargar la copia, restringirla por RBAC y bloquear exportaciones.	Permisos y auditoría.
7. Renovación/borrado	Regenerar por ciclo y eliminar copias vencidas de forma segura.	Acta de eliminación.

Aporte al cumplimiento. El enmascaramiento reduce los datos identificables, limita el uso secundario, aplica minimización y privacidad por diseño, y permite demostrar medidas proporcionales. No sustituye controles de acceso, cifrado, auditoría ni una base legal válida.

3. Revisión de controles de acceso

3.1 Evaluación de DAC, MAC y RBAC

Modelo	Ventaja	Limitación en BioHealth	Decisión
DAC	Flexible: el propietario concede permisos.	Decisiones descentralizadas, inconsistentes y difíciles de auditar.	No usar como modelo principal.
MAC	Políticas y etiquetas obligatorias; control muy riguroso.	Mayor complejidad y menor flexibilidad operacional.	Aplicarlo selectivamente a datos restringidos.
RBAC	Permisos asociados a funciones; escalable y auditable.	Requiere diseñar roles y evitar acumulación de privilegios.	Modelo principal recomendado.

RBAC es el modelo más adecuado porque BioHealth tiene funciones claramente diferenciadas: médicos, laboratorio, admisión, facturación, soporte, desarrollo, administradores y auditores. Los permisos deben concederse a roles y no directamente a personas. Para información especialmente crítica puede reforzarse con etiquetas y reglas obligatorias inspiradas en MAC, además de condiciones contextuales como dispositivo gestionado, ubicación, horario y relación con el paciente.

3.2 Matriz RBAC propuesta

Rol	Historia clínica	Resultados	Exportar	Administrar usuarios	Ambiente de pruebas
Médico tratante	Lectura/escritura de sus pacientes	Lectura	Restringido y justificado	No	Datos enmascarados
Laboratorio	Lectura mínima	Carga/validación	No	No	Datos enmascarados
Admisión	Datos demográficos mínimos	No	No	No	Datos enmascarados
Soporte	Acceso temporal supervisado	Solo si el incidente lo exige	No	No	Enmascarado dinámicamente
Desarrollo/QA	No	No	No	No	Acceso funcional a datos sintéticos/enmascarados
Administrador IAM	No	No	No	Sí, con doble control	No
Auditor/DPO	Solo lectura justificada	Solo lectura	Evidencia mínima	No	Logs y políticas

3.3 Aplicación del modelo AAA

Componente	Aplicación	Evidencia esperada
Autenticación	Identidades individuales, SSO, MFA, bloqueo adaptativo, dispositivos gestionados y cuentas de servicio con certificados/secretos rotados.	Reporte MFA, inicios de sesión, altas y bajas.
Autorización	RBAC, mínimo privilegio, segregación de funciones, aprobación del dueño, acceso temporal para soporte y recertificación trimestral.	Matriz de roles, solicitudes, aprobaciones y revisiones.
Auditoría	Registrar consulta, modificación, exportación, autenticación y uso privilegiado; centralizar alertas y proteger logs contra alteración.	Logs con usuario, fecha, paciente/recurso, acción, resultado y origen.

Regla esencial. Las cuentas compartidas deben eliminarse. Una acción clínica o administrativa solo es atribuible si cada persona utiliza una identidad individual y los registros mantienen tiempo sincronizado.

4. Controles de seguridad

Categoría	Control	Cómo mejora la seguridad
Preventivo	MFA y RBAC	Evitan accesos con una sola credencial y limitan acciones al rol necesario.
Preventivo	Enmascaramiento y datos sintéticos	Impiden que pruebas expongan identidades e historiales reales.
Preventivo	Cifrado y gestión de claves	Reduce la utilidad de datos robados o interceptados.
Preventivo	Segmentación y hardening	Aísla producción/pruebas y reduce servicios vulnerables.
Detectivo	Registros centralizados/SIEM	Identifica accesos anómalos, exportaciones masivas y abuso de privilegios.
Detectivo	DLP y alertas de compartición	Detecta intentos de enviar datos clínicos por canales no autorizados.
Detectivo	Monitoreo de integridad	Advierte alteraciones de archivos, configuraciones o registros críticos.
Detectivo	Revisión periódica de accesos	Encuentra privilegios obsoletos o incompatibles con la función.
Correctivo	Revocación de sesiones y credenciales	Corta accesos comprometidos y limita el alcance del incidente.
Correctivo	Restauración desde copias verificadas	Recupera disponibilidad e integridad después de pérdida o corrupción.
Correctivo	Aislamiento y reconstrucción segura	Evita propagación y elimina persistencia en equipos afectados.
Correctivo	Plan de respuesta y notificación	Coordina contención, evidencia, comunicación y aprendizaje posterior.

4.1 Relación con controles físicos, lógicos y administrativos

Naturaleza	Ejemplos en BioHealth
Físicos	Acceso biométrico/tarjeta a servidores, CCTV, registro de visitantes, racks cerrados, UPS y destrucción segura de soportes.
Lógicos	MFA, RBAC, cifrado, DLP, EDR, firewall, SIEM, enmascaramiento, copias y bloqueo de exportaciones.
Administrativos	Política de privacidad, clasificación, retención, formación, respuesta, acuerdos de confidencialidad y auditoría.

5. Estrategia de cifrado

5.1 Datos en reposo

- Cifrar bases de datos, discos, objetos, documentos y respaldos con un algoritmo simétrico robusto, como AES-256.
- Separar claves de los datos mediante KMS/HSM; prohibir claves en código fuente, tickets o archivos compartidos.
- Usar claves distintas por entorno y propósito; rotarlas y revocarlas por calendario o incidente.
- Cifrar campos especialmente sensibles o aplicar tokenización adicional a identificadores.
- Registrar el uso administrativo de las claves y aplicar doble control a operaciones críticas.

5.2 Datos en tránsito

- Usar TLS 1.2 o 1.3 en portales, APIs, integraciones, correo y administración.
- Validar certificados, nombres, vigencia y cadena de confianza; automatizar renovación.
- Proteger conexiones internas entre aplicaciones y bases, no únicamente el perímetro.
- Usar VPN o canales privados para administración y enlaces entre sedes.
- Deshabilitar HTTP, FTP, Telnet y versiones criptográficas obsoletas.

5.3 Combinación simétrica y asimétrica

Tipo	Funcionamiento	Uso propuesto
Simétrico	La misma clave cifra y descifra; es rápido y eficiente para grandes volúmenes.	Datos clínicos, bases, discos, archivos, backups y sesiones.

Tipo	Funcionamiento	Uso propuesto
Asimétrico	Par de clave pública/privada; facilita autenticación, intercambio y firma, pero es más costoso.	Certificados TLS, intercambio/protección de claves, firmas digitales e identidades de servicios.
Híbrido	El asimétrico autentica/acuerda una clave; el simétrico protege los datos.	HTTPS/TLS y cifrado de datos con claves envolventes administradas por KMS.

Justificación. El modelo híbrido combina la eficiencia necesaria para millones de registros con la distribución segura de claves y la autenticación requerida en sistemas distribuidos. El cifrado protege la confidencialidad, pero no reemplaza RBAC, auditoría ni controles de integridad.

6. Google Workspace como solución complementaria

Google Workspace puede reforzar el acceso a correos institucionales y documentos compartidos si se administra como plataforma corporativa y no como almacenamiento abierto. No reemplaza el sistema clínico ni debe utilizarse para compartir historiales sin una evaluación legal, contractual y de configuración. Su papel principal será proteger identidades, colaboración, retención y trazabilidad.

6.1 Configuraciones recomendadas

Área	Configuración
Identidad	SSO, verificación en dos pasos obligatoria, llaves de seguridad para privilegiados y bloqueo de aplicaciones menos seguras.
Acceso contextual	Permitir información sensible solo desde cuentas corporativas, dispositivos gestionados y condiciones aprobadas.
Compartición	Restringir enlaces públicos, limitar compartición externa, establecer caducidad y advertencias por información sensible.
Dispositivos	Gestión de endpoints, cifrado, bloqueo de pantalla, borrado remoto y control de sesiones.
Protección de datos	Reglas DLP para DNI, identificadores clínicos y términos sensibles; clasificación y etiquetas.
Correo	Protecciones antiphishing, SPF/DKIM/DMARC, cuarentena, alertas y bloqueo de reenvío no autorizado.
Retención	Google Vault para conservación, búsqueda, retención y borrado conforme a obligaciones.
Supervisión	Registros de actividad, alertas y paneles; integración con el proceso de respuesta a incidentes.

Área	Configuración
Administración	Roles administrativos separados, cuentas de emergencia controladas y revisión periódica de privilegios.

6.2 Aplicación de la tríada CID

Pilar	Funciones aplicables	Resultado
Confidencialidad	MFA, SSO, acceso contextual, cifrado, DLP, restricciones de compartición y dispositivos gestionados.	Solo usuarios y dispositivos autorizados acceden a información institucional.
Integridad	Historial de versiones, auditoría, permisos, restauración de versiones y control de cambios/compartición.	Cambios atribuibles y posibilidad de recuperar una versión confiable.
Disponibilidad	Infraestructura cloud redundante, acceso controlado, retención, restauración y recuperación de cuentas/archivos.	Continuidad de colaboración, sujeta a respaldo y plan de contingencia propios.

Precaución. La existencia de certificaciones del proveedor no hace que BioHealth cumpla automáticamente. La empresa conserva responsabilidad sobre configuración, identidades, clasificación, compartición, retención, licencias adecuadas y contratos aplicables.

7. Plan inmediato de implementación

Plazo	Acciones	Evidencia
0-72 horas	Detener copias; aislar bases de prueba; inventariar usuarios; revocar accesos injustificados; preservar logs.	Acta de contención y lista de accesos eliminados.
Primera semana	Clasificar datos; definir roles; activar MFA; establecer propietario; analizar obligaciones y brechas.	Matriz de datos/RBAC y reporte MFA.
30 días	Automatizar enmascaramiento; cifrado/KMS; SIEM/DLP; reglas Workspace; capacitación.	Pruebas de enmascaramiento, configuración y alertas.
60-90 días	Recertificar permisos; probar respuesta y restauración; evaluar reidentificación; auditar controles.	Informe de pruebas, hallazgos y plan correctivo.

8. Evidencias para verificar la propuesta

Control	Evidencia mínima	Estado en este análisis
Enmascaramiento	Muestra antes/después con datos ficticios, prueba de referencialidad y reidentificación.	Diseñado; implementación pendiente.
RBAC/AAA	Matriz, reporte MFA, acceso permitido/denegado y log asociado.	Diseñado; implementación pendiente.

Control	Evidencia mínima	Estado en este análisis
Controles	Alertas SIEM/DLP, aislamiento y restauración controlada.	Propuestos; pruebas pendientes.
Cifrado	Configuración TLS, cifrado en reposo y reporte de claves sin revelar secretos.	Estrategia definida.
Workspace	Políticas de 2FA, compartición, DLP, Vault y auditoría.	Configuraciones recomendadas.
Cumplimiento	Evaluación legal, registro de riesgos y aprobación del responsable.	Debe completarse con normativa local.

Estas evidencias pueden demostrarse en un laboratorio o VM para fines académicos; no obstante, el caso solicita principalmente un análisis consultivo. Por honestidad técnica, el informe diferencia los controles diseñados de los controles efectivamente implementados y verificados.

9. Reflexión final

Este caso demuestra que proteger datos no consiste solamente en instalar herramientas. Primero es necesario comprender qué información se trata, para qué se utiliza, quién debe acceder y qué daño produciría su exposición o alteración. BioHealth evidencia un problema frecuente: reutilizar datos reales para facilitar las pruebas sin considerar que cada copia amplía el riesgo y puede apartarse de la finalidad original.

El enmascaramiento permite mantener la utilidad técnica sin revelar identidades; RBAC y AAA convierten el acceso en una decisión controlada y trazable; los controles preventivos, detectivos y correctivos crean defensa en profundidad; y el cifrado híbrido protege la información durante su almacenamiento y transmisión. Google Workspace puede complementar estas medidas siempre que se configure con criterios de mínimo privilegio, protección de datos y auditoría.

Como estudiante de ciberseguridad, concluyo que la decisión más importante no es escoger una herramienta aislada, sino integrar personas, procesos y tecnología. La seguridad debe demostrarse mediante evidencias y revisarse continuamente. Con este enfoque, BioHealth puede reducir el riesgo para los pacientes, responder a las exigencias regulatorias y fortalecer la confianza en sus servicios digitales.